

LEY MARCO DE CIBERSEGURIDAD N°21.663

Registro de Amenazas y Vulnerabilidades

Normativa	Ley Marco de Ciberseguridad N°21.663
Organización	Laboratorio Clínico ACLIN Ltda.
Responsable de Ciberseguridad	Paulina Tapia Hernández (CISO)
Versión del documento	1.0
Período de cumplimiento	Octubre 2025 – Octubre 2026
Fecha de emisión	15 / 03 / 2026

Clasificación: Confidencial — Jaime Gómez Ayala — Auditor Externo de Ciberseguridad

1. PROPÓSITO

Documentar las amenazas y vulnerabilidades identificadas en los activos tecnológicos del Laboratorio Clínico ACLIN Ltda., con el objetivo de evaluar los riesgos de ciberseguridad y definir medidas de mitigación.

2. ALCANCE

Este registro aplica a los sistemas clínicos, bases de datos de pacientes, infraestructura de red, servicios cloud y demás activos tecnológicos utilizados por la organización.

3. MARCO NORMATIVO

- Ley Marco de Ciberseguridad N°21.663
- ISO/IEC 27001 – Gestión de Seguridad de la Información
- ISO/IEC 27005 – Gestión de Riesgos
- NIST Cybersecurity Framework

4. VULNERABILIDADES CRÍTICAS ACTIVAS — ACCIÓN URGENTE

Las siguientes vulnerabilidades son de nivel **CRÍTICO** y se encuentran activas. Requieren corrección inmediata.

ID	Activo	Amenaza	Vulnerabilidad	Impacto	Probabilidad	Nivel	Mitigación	Responsable
V-06	pacientes.aclin.cl	IDOR / Acceso exams. terceros	Sin validación de sesión en /verexamen.s.asp (~21.000 exámenes expuestos)	5	5	CRÍTICO	Validación sesión, reCAPTCHA, auditoría accesos	Desarrollo / TI

V-07	MSSQL (BD clínica)	Acceso remoto no autorizado	Puerto 1122/tcp expuesto a Internet — SQL Server 2019 v15.00.2000	5	4	CRÍTICO	Cerrar puerto, FW perimetral, red interna only	TI Infraestructura
V-08	pacientes.aclin.cl	MITM / Interceptación	HTTP sin cifrado — datos médicos transmitidos sin TLS/SSL	5	4	CRÍTICO	SSL/TLS + HSTS + HTTP→HTTPS	TI Infraestructura

5. VULNERABILIDADES ALTAS Y MEDIAS

ID	Activo	Amenaza	Vulnerabilidad	Impacto	Probabilidad	Nivel	Mitigación	Responsable
V-01	Servidor LIS	Ransomware	Sin EDR instalado	5	3	Alto	EDR + segmentación red	Área TI
V-02	BD Pacientes	Filtración datos	Credenciales débiles	5	3	Alto	MFA + cifrado BD	CISO
V-03	Correo institucional	Phishing	Usuarios sin capacitación	4	4	Alto	Capacitación + filtros	Área TI
V-04	Sistema backups	Falla reLtda.Ido	Backups no probados	5	2	Medio	Pruebas trimestrales	Área TI
V-05	Red interna	Acceso no autorizado	Reglas FW débiles	4	3	Medio	Actualizar reglas + monitoreo	TI Infraestructura
V-09	IIS 10.0 (web server)	XSS / Clickjacking	Headers HTTP faltantes (CSP, X-Frame, etc.)	3	2	Medio	Config. headers IIS	TI Infraestructura

6. USO DEL REGISTRO

Este registro sirve como insumo para el análisis de riesgos, la Matriz de Riesgos de Ciberseguridad y el Plan de Tratamiento de Riesgos.

7. REVISIÓN

El registro de amenazas y vulnerabilidades deberá revisarse al menos una vez al año o cuando se detecten nuevas amenazas relevantes.

8. APROBACIÓN · VIÑA DEL MAR, CHILE

Representante Legal / CEO – ACLIN Ltda.

Marcelo Tapia Carrere

Firma

Auditor Externo · RUT 16.302.178-1

Jaime Gómez Ayala

Firma

Fecha de aprobación: ____ / ____ / 2026